Cybersécurité des systèmes industriels

Sécurisation d'un système de production industriel

Pierre-Louis Filoche

Leçon M2FESup DER SIEN

école normale supérieure paris—saclay

université PARIS-SACLAY

Les sources sont disponibles via lien cliquables sur les diapositives concernées

Séquence Pédagogique

Comment protéger des systèmes aussi complexes que les systèmes industriels ?

Objectif global

Comprendre les contraintes d'un système industriels (SI).
Mettre en œuvre les compétences permettant de concevoir et déployer un SI sécurisé (pare-feux, VPN, VLAN,DMZ authentification, supervision).

Volume horaire

6h cours + 12h TP

Prérequis

- Notions de réseaux (adressage IP, VLAN, routage)
- Bases de la sécurité (pare-feu, protocole HTTPS)
- Administration système (Linux/Windows Server)

Evaluation :

- TP noté en cours + CR (50%)
- QCM (20%)
- Une partie de l'examen Cybersécurité (30%)

Séquence Pédagogique

Public visé : BUT R&T (semestre 4) option cyber

Ressources visées	Savoirs de références étudies correspondant
R4.01 : Infrastructures de sécurité	- Administrer les réseaux et l'Internet - Connecter les entreprises et les usagers
R4.Cyber.09 : Sécurité des réseaux LAN	
R4.Cyber.11 Sécurisation de services réseaux	- Administrer un système d'information sécurisé - Surveiller un système d'information sécurisé

Séquence Pédagogique

Plan de cours en 4 blocs

1. Introduction cyber Sécurité (1h)

2. Mise en œuvre des infrastructures de sécurité (2h)

Pare-feux, DMZ, IDS/IPS

3. Sécurisation des réseaux LAN et services (2h)

VPN, VLAN, ACL, DHCP, DNS sécurisés

4. Cyber Sécurité Système Industriel (1h)

Tests d'intrusion simulés, supervision

Travaux Pratiques (12h)

Considérer une usine réelle simulée (cas concret) avec un plusieurs sites.

- Analyse fonctionnelle
- connexion sécurisée VPN site-à-site entre les 2 routeurs
- supervision simplifiée
- le stockage dans le serveur de base de données
- Sensibilisation
- Cartographie
- …

=> Réfléchir à une architecture réelle

Séquence Pédagogique

2.2.1. SAÉ 4.Cyber.01 : Sécuriser un système d'information

Compétences ciblées :

- Administrer un système d'information sécurisé
- Surveiller un système d'information sécurisé

Objectifs et problématique professionnelle :

Le professionnel R&T spécialisé dans la Cybersécurité se doit de sécuriser un réseau multi-sites tant au niveau des équipements que des services.

Descriptif générique :

Afin de procéder à la sécurisation des équipements et des services, le professionnel Cyber se doit de :

- sécuriser l'infrastructure locale existante et ce de manière ascendante notamment en commençant par les éléments actifs de couches supérieures à 3, pour finir par les différents services proposés (DNS, Web, ...) ;
- ajouter des équipements spécialisés ;
- utiliser des outils cryptographiques judicieusement choisis pour sécuriser les services (authentification, certificats, ...) ;
- se référer aux recommandations de l'ANSSI pour sécuriser un système d'information.

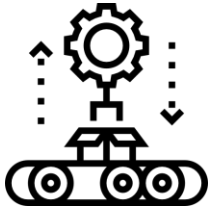
Cette SAÉ fait suite à la SAÉ3.03Cyber "Concevoir un réseau informatique sécurisé multi-sites" qui a débouché sur la conception d'un réseau multi-sites.

Plan de cours

I. Introduction
- i. Cybersécurité et Systèmes Industriels (SI) : définition
- ii. Cyberattaques : quels vecteurs ?
- iii. Pourquoi une attention particulière au SI ?

II. Architecture des Systèmes industriels
- i. Différents modèles
- ii. Cas concret





III. Protection et solution
- i. Méthode ANSSI[2]
- ii. Protocoles modernes

IV. Quizz

[2] Agence Nationale de la Sécurité des Systèmes d'Information

Définitions

Cyber Sécurité

c.f. le cours de A.Juton d'il y a 13 jours

"Ensemble des technologies, pratiques et politiques destinées à prévenir les cyberattaques ou à en atténuer l'impact. "
IBM

Systèmes Industriels

" Les systèmes industriels sont constitués d'une succession de traitements qui aboutissent à l'exécution d'actions en temps réel sur des machines. "
Techniques de l'ingénieur

Définitions

Cyber Sécurité

Protection des ordinateurs
En gros

Systèmes Industriels

Personnes qui commandent des machines pour produire quelque chose.
En gros

=> **Protéger les machines et les ordinateurs d'une usine contre les pirates pour éviter les pannes ou les accidents.**

Les types d'attaques Moyens d'introduction

Phishing

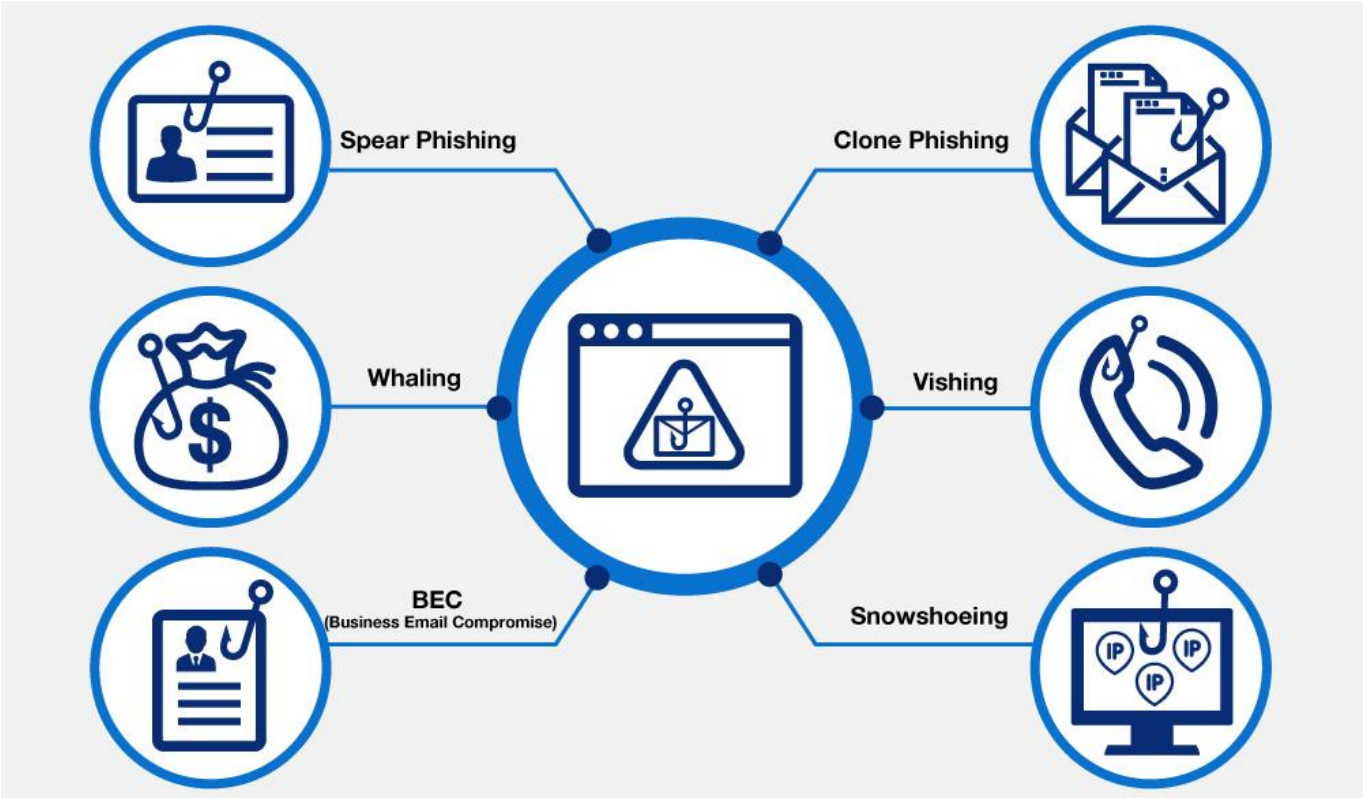
Mail utilisant un aspect officiel pour demander des données personnelles

Plus il est personnalisé, plus il est efficace

Utilisation de détails concernant la cible

statista

Affaire Podesta



Différents types de phishing

Les types d'attaques Moyens d'introduction

Mot de passe faible BruteForce

Accès via tentative de connexion sans ou avec peu d'informations

User : *admin*
Pwd : LOUVRE

Vulnérabilité info/humaine

Faille logicielle / introduction d'un périphérique

Ver informatique

Programme qui se reproduit sur plusieurs ordinateurs

Utilise le réseau informatique pour se propager

Se spread rapidement sans intervention humaine

Les types d'attaques Moyens de sabotage

Cheval de Troie

Programme qui permet de prendre à distance le contrôle de l'ordinateur cible

Récupère des informations comme les login et mot de passe

Installation via site web, périphérique ou logiciel malveillant

Backdoor

Ouverture d'un accès distant

Accéder, modifier ou contrôler un système à distance sans autorisation

Utilisation de détails concernant la cible

Ransomware

Programme qui chiffre les fichiers et qui demande une rançon pour les déchiffrer

Impact direct sur la production et les opérations industrielles

Les Systèmes Industriels dans tout ça ?

Technologies spécifiques

Certains automates des années 80 sont toujours en activités, protocoles spécifiques non sécurisable

problèmes : **hétérogénéité du parc (marque et modèles différents), complexité de suivi**

Continuité de service

Le système doit être fonctionnel sans interruptions

màj, tests



Conséquences ++

Mise en jeux de la vie de personne

Certifications et habilitations spécifique



Intervenants ext

Appels à des sous traitans multiples

Multiplie les points d'acès



Les Systèmes Industriels dans tout ça ?

Organisme d'Importance Vitale

- Activités civiles de l'Etat
- Activités judiciaires
- Activités militaires de l'Etat
- Alimentation
- Communications électroniques
- Audiovisuel et information
- Energie
- Espace et recherche
- Finances
- Gestion de l'eau
- Industrie
- Santé
- Transports

+200 services publiques ou entreprises

Loi de Programmation militaire (2013)

Audit de l'ANSSI

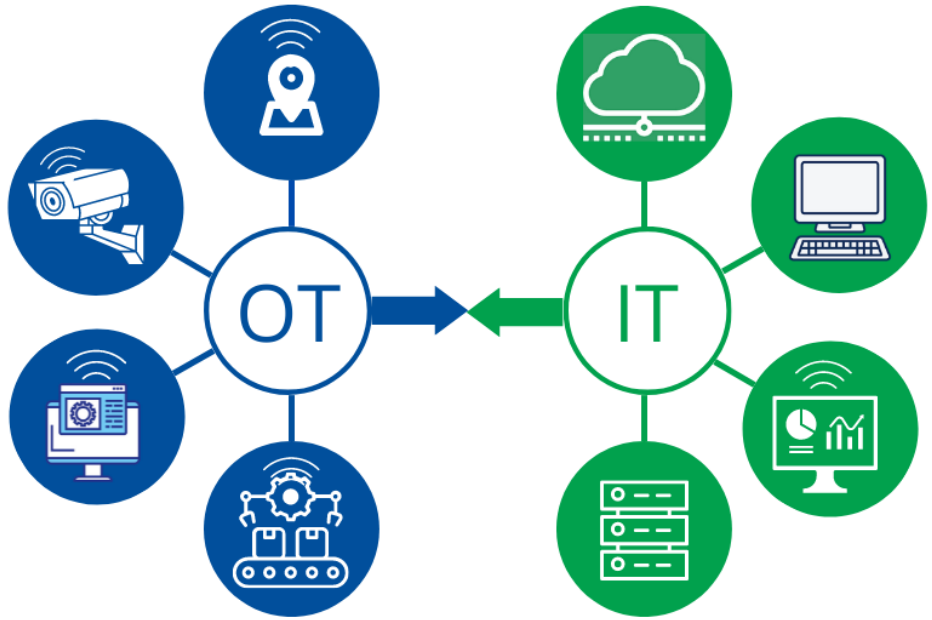
Sécurité Gestion

Machines physiques

Continuité de service

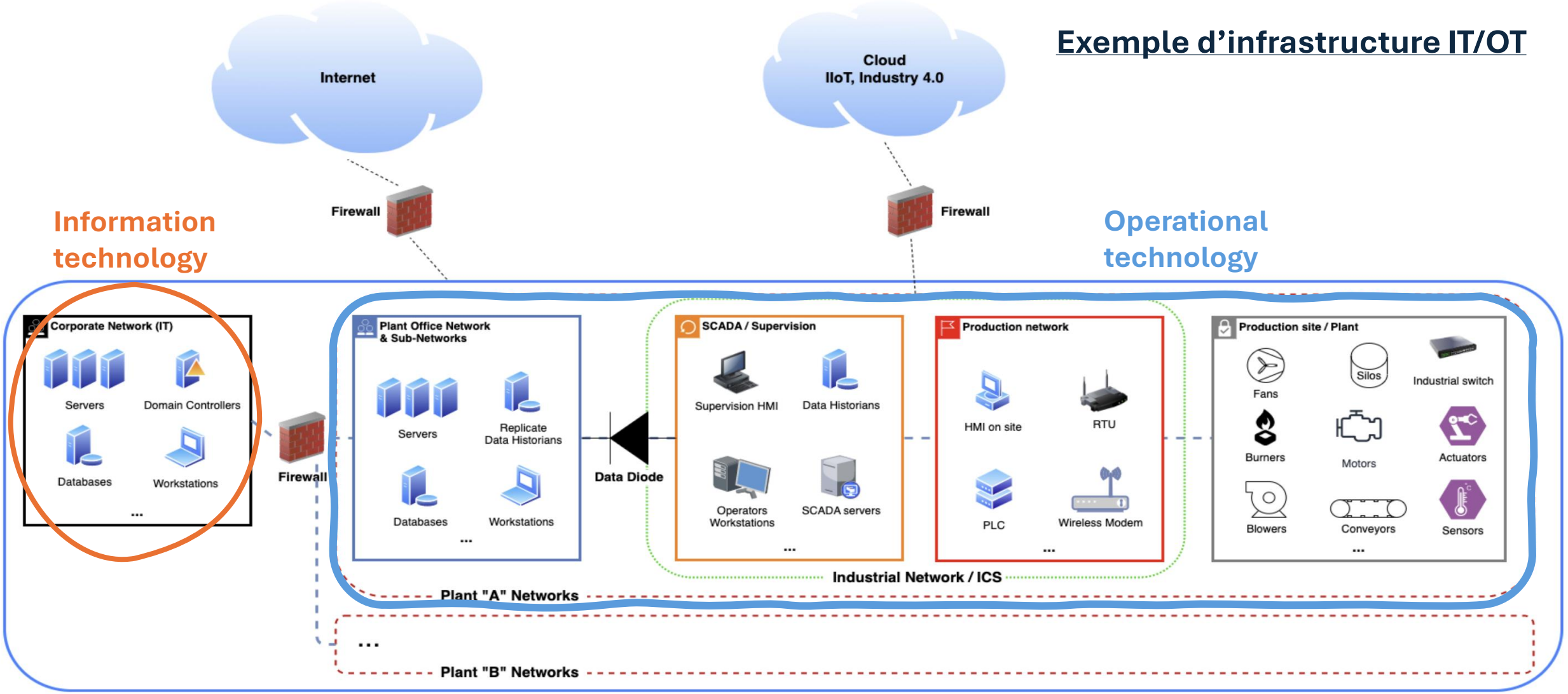
Systèmes industriels

<u>Redondance et Segmentation</u> de la structure du système industriel



Information Technology (IT) vs Operational Technology (OT)

Exemple d'infrastructure IT/OT



Deux modèles de références

Modèle PERA

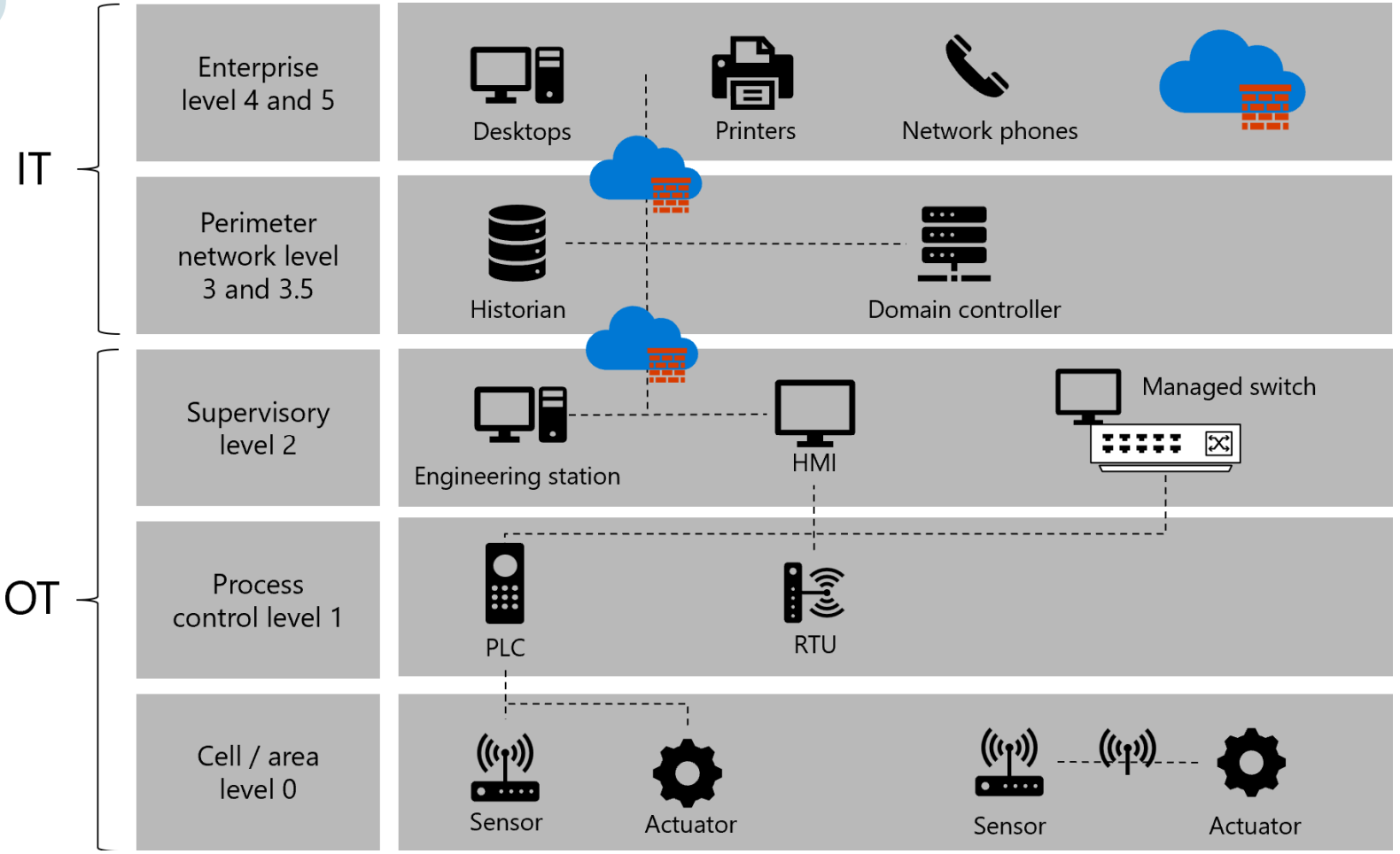
Purdue Enterprise Reference Architecture

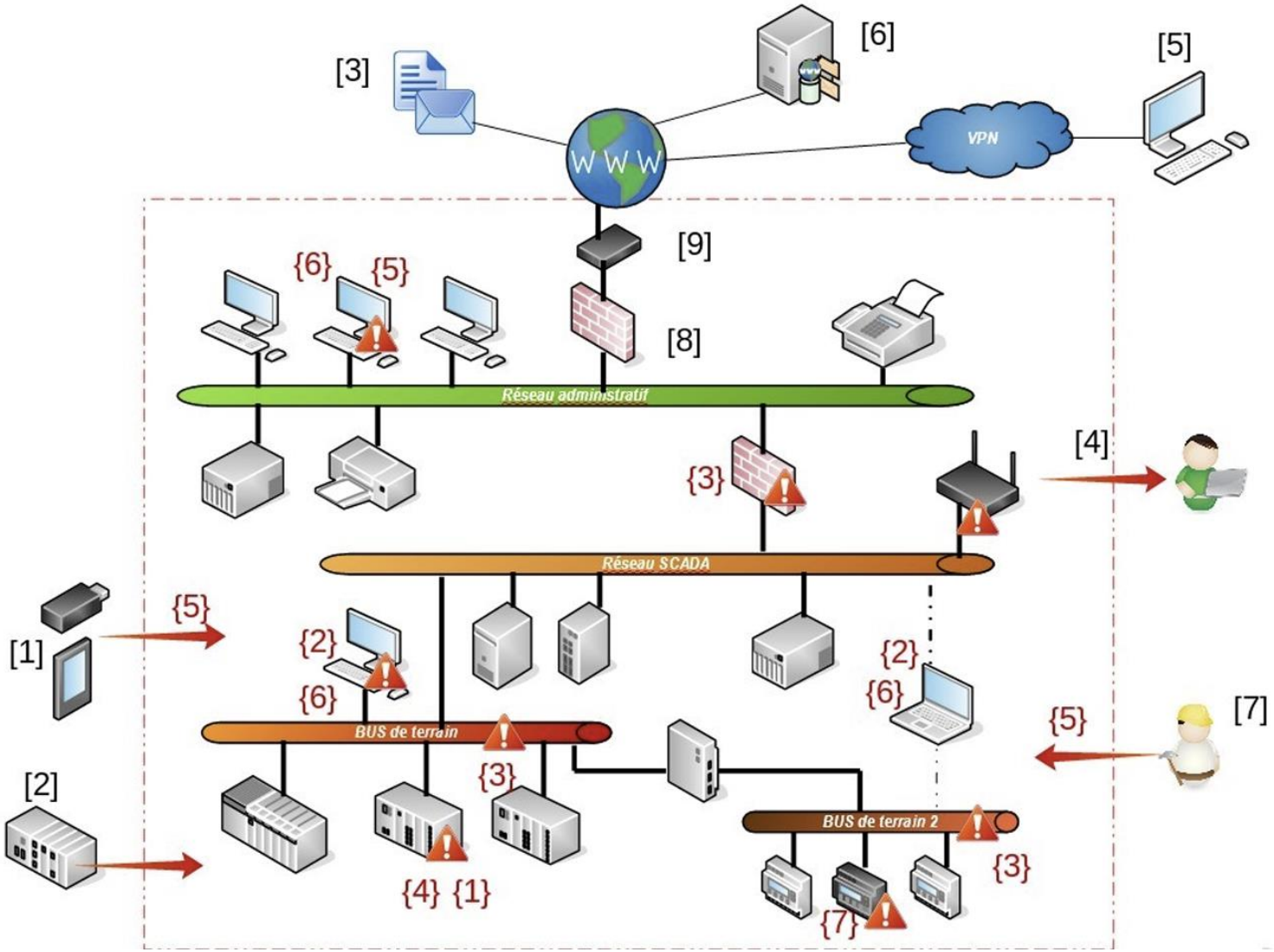
- Architecture en couche
- **confiance par couche**
- Séparation IT/OT

Modèle Zero Trust

- architecture maillée
- **pas de confiance implicite**

Modèle PERA

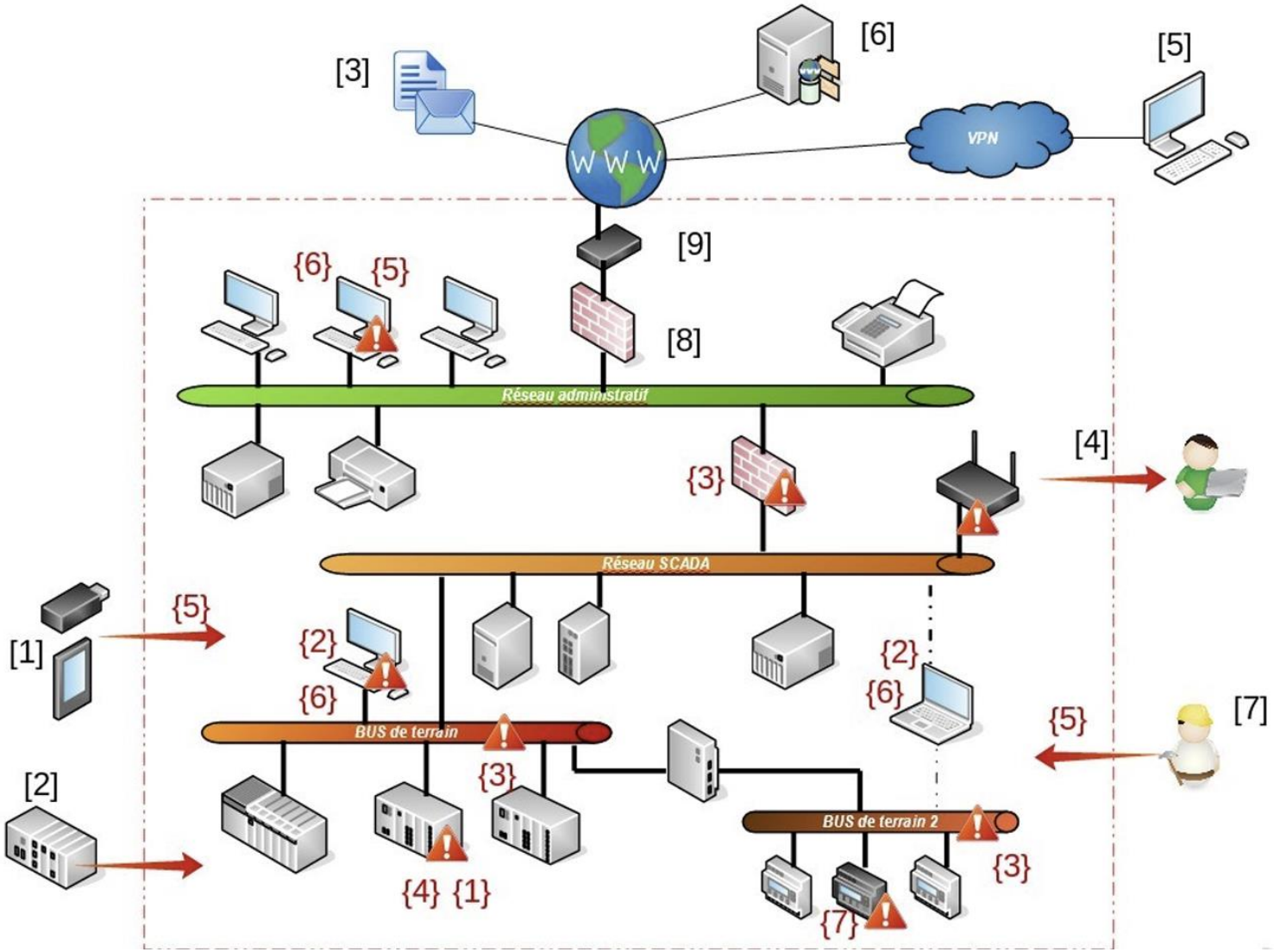

IT
OT
Enterprise level 4 and 5
Perimeter network level 3 and 3.5
Supervisory level 2
Process control level 1
Cell / area level 0
Desktops
Printers
Network phones
Historian
Domain controller
Engineering station
HMI
Managed switch
PLC
RTU
Sensor
Actuator
Sensor
Actuator



Exemple de vulnérabilités d'un système (3EI)

Les vecteurs de pénétration des systèmes[] :

- [1] Introduction de périphériques infestés
- [2] l'introduction de nouveaux matériels qui peuvent être infectés en amont de la livraison
- [3] les courriers électroniques contenant des pièces jointes
- [4] le réseau Wifi qui dépasse les murs de l'entreprise
- [5] les connexions à distance comme les VPN
- [6] les liaisons entre les logiciels tiers et leurs serveurs
- [7] les intervenants extérieurs qui peuvent se retrouver à introduire des clefs USB et autres vecteurs d'infection
- [8] une mauvaise configuration de pare-feu
- [9] une mauvaise configuration des modems



Exemple de vulnérabilités d'un système (3EI)

Les failles permettant la prise de contrôle{} :

- {1} des matériels comportant des failles de sécurité
- {2} les systèmes d'exploitation faillibles et obsolescents
- {3} l'absence de ségrégation des réseaux
- {4} l'absence de gestion des malwares sur tous les composants des systèmes SCADA
- {5} l'erreur humaine ou la non-formation aux risques
- {6} l'absence de mise à jour régulière
- {7} l'hétérogénéité des composants industriels, des protocoles de communication qui ne prennent pas en compte la sécurité
- Des mots de passe par défaut en dur et non chiffrés

Automaticiens
bons connaisseurs de leurs équipements industriels



Informaticiens
formés en cybersécurité

=

Système industriel protégé

1. **Sensibilisation** des personnels
2. **Cartographie** des installations et analyse de risque
3. **Prévention** : concept de la défense en profondeur
4. **Surveillance** des installations et **détection** des incidents
5. Traitement des incidents, **chaîne d'alerte**
6. **Veille** sur les menaces et les vulnérabilités
7. **Plans** de reprise et de continuité d'activité

Méthode de protection d'un système (ANSSI)

1. Sensibilisation du personnel



2. Cartographie des installations et analyse de risque



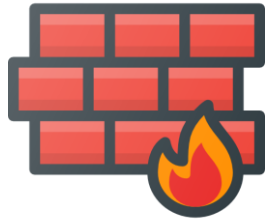
- Inventaire des installations matérielles (référence de l'équipement, version, protections, accès)
- Architecture réseau
- Communications entre les équipements internes et externes

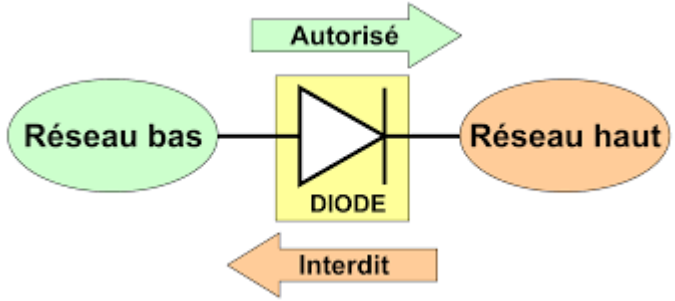
3. Prévention : concept de la défense en profondeur

Tout est interdit par défaut

- accès nécessaires aux personnes concernées
- connexions UDP/TCP utiles
- logiciels indispensables

Pare-feu
DMZ
Diode Réseau
Cloisonnement du réseau
Protection virale
Durcissement des configurations





4. Surveillance des installations et détection des incidents

Détection de l'incident le plus vite possible (surveillance du Traffic, journaux …)

=> Isolement physique de la zone de l'incident (propagation)

5. Traitement des incidents, chaîne d'alerte

- Que faire lors de la détection d'un incident ?
- Qui alerter ?
- Quelles sont les premières mesures à appliquer ?

=> Procédure claire et efficace

6. Veille sur les menaces et les vulnérabilités

- Se tenir au courant des dernières actualités 'cyber'
- Se tenir au courant des maj des systèmes utilisés (OS, firmwares …)

7. Les plans de reprise et de continuité

Données, configurations, licences,....



Sauvegarde froide

Mode dégradé

Approvisionnement

Protocoles industriels – OPC UA

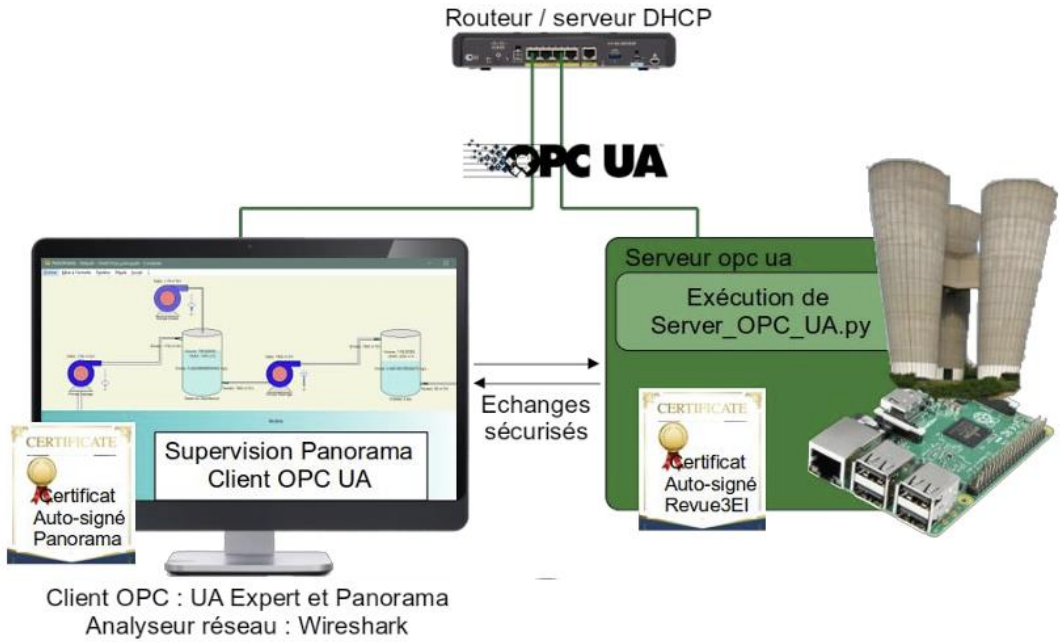
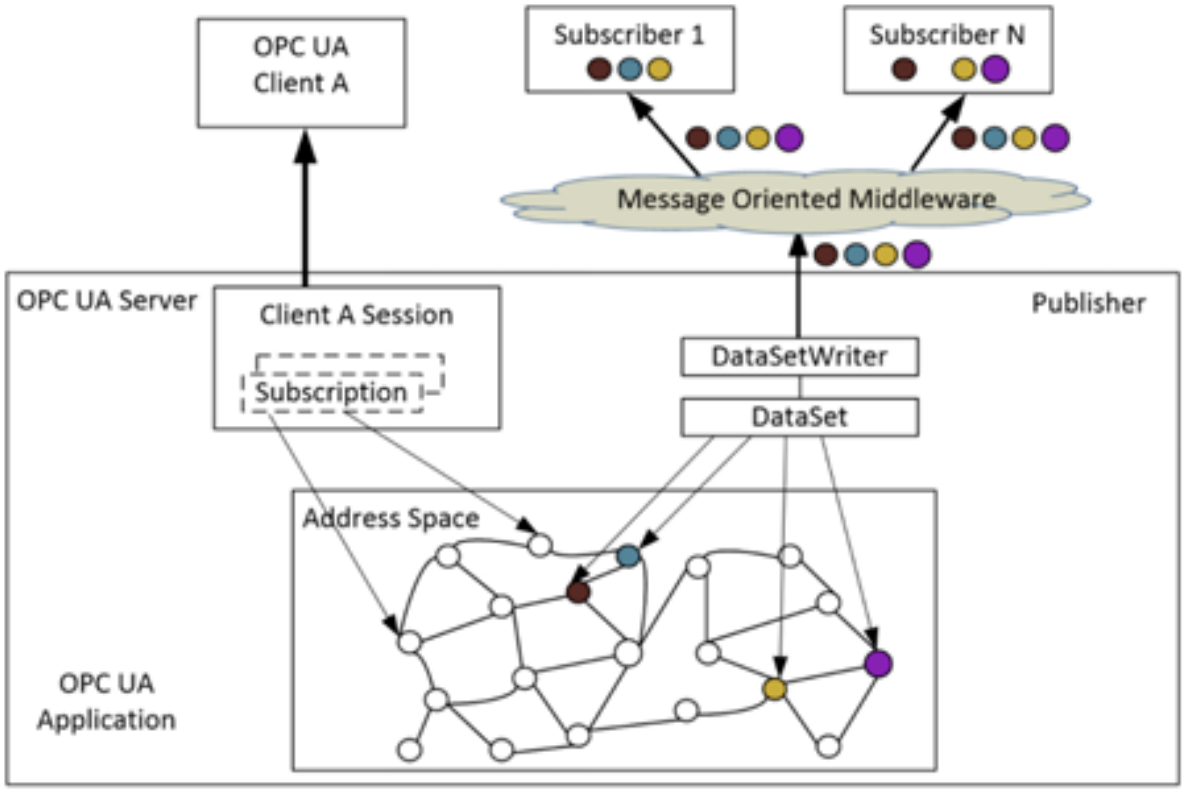


Schéma installation utilisant OPC UA



Modes de communication

Quizz

Kahoot



Impact

Arrêt de production d'électricité pendant **15 jours**

Scénario d'incident

Impossibilité d'accéder au système de communication avec l'hydrolienne à cause d'un **rançongiciel**

Vulnérabilité

Connectivité directe à Internet du système sans protection (absence de pare-feu)

Gravité de l'attaque	Motivation de l'attaquant	Complexité de l'attaque
Faible	Financière	Faible

Déroulement de l'attaque

- Les attaquants ont **chiffré le serveur** permettant la connexion satellitaire avec l'unité de pilotage de l'hydrolienne.
- Ils ont demandé **une rançon de 4000$** à payer par PayPal ou par bitcoin afin de rétablir la connexion.
- Sabella a refusé de payer ce qui a conduit à **une interruption du système** en phase de test pendant 15 jours.



Moyens mis en œuvre

- Un rançongiciel
- Connexion internet

Explosion d'un pipeline

CLUSIF

2008 | Pétrole & Gaz | Turquie | Fiche 5

Origine informatique de l'incident contestée



Impact

Destruction du pipeline de Baku-Tbilisi-Ceyhan (BTC), Destruction de matériel, 20 jours d'indisponibilité (plus de **1 Md$** de pertes en matériel et recettes)

Scénario d'incident

Désactivation des systèmes de monitoring et **d'alarmes** puis explosion

Vulnérabilité

Logiciel des caméras, accès aux vannes, réseau radio exposé

Destruction d'un système d'information - Shamoon

2012 | Pétrole & Gaz | Dhahran, Arabie Saoudite | Fiche 6

Gravité de l'attaque

Élevée

Motiva

Déroulement de l'attaque

- Un employé de la compagnie ayant un compte privilégié a probablement cliqué sur un lien contenu dans un message SCAM (**hameçonnage**).
- Le **virus Shamoon** s'est rapidement déployé à l'ensemble du réseau **30000 postes de travail, 2000 serveurs.**
- Le virus exfiltrait les fichiers des postes et serveurs, puis les supprimait. Ensuite, le virus détruisait les machines **en réécrivant le secteur d'amorçage** du disque.
- Le cœur de métier a été impacté: gestion des commandes, des stocks, livraison, facturation… Seule l'extraction pétrolière n'a pas été affectée (officiellement, réseau SCADA séparé).

Impact

Incapacité à livrer les clients, **facturation partielle**, **retour à la normale après 5 mois**

Scénario d'incident

Destruction totale ou partielle et suppression de fichiers sur **30 000 postes de travail et 2 000 serveurs**



Impact

Prise de contrôle d'un véhicule, obligation de rappel des véhicules (1,4 millions de véhicules)

Scénario d'incident

Prise de contrôle du véhicule par deux chercheurs

Vulnérabilité

Réseau WiFi avec clé prédictible et **vulnérabilités d'un contrôleur attaché au CAN bus** (réseau interne interconnectant les fonctions du véhicule)

Gravité de l'attaque

Élevée

Moti

Déroulement de l'attaque

- Certaines voitures sont équipées d'une option permettant au conducteur de **contrôler la console de bord par WiFi**. Les chercheurs ont réussi, en découvrant la clé Wifi, à s'introduire dans le réseau sans fil. Ils ont pris le contrôle de la console de bord en **exploitant ses vulnérabilités**.
- Les véhicules du même modèle sont connectés au réseau GSM. En utilisant une antenne GSM, les chercheurs ont réussi à **accéder à distance à la console de bord**.
- Cette console est connectée au CAN bus (réseau interne interconnectant les fonctions du véhicule), à travers un autre composant, le V850.
- En **modifiant le firmware** du V850, les chercheurs ont envoyé des commandes au véhicule.